CAPABILITIES OVERVIEW

GOVERNED AGENTS INSIDE YOUR BOUNDARY

Papyrus runs named, signed AI agents in your own environment, including disconnected and classified enclaves. People stay accountable for what each agent may do, every security event is recorded, and nothing leaves the boundary unless you allow it.



800-53 CONTROLS MAPPED **50 (26 implemented, 22 partial, 2 customer owned)**	NIST AI RMF **19 subcategories mapped, plus the Generative AI Profile**
CRYPTOGRAPHY **FIPS 140-3 (OpenSSL provider, CMVP #5438), enforced at startup**	RELEASE REVIEWED **0.1.0+a3d9ded**

AWARDABLE ON TRADEWINDS

Papyrus is listed on the Chief Digital and Artificial Intelligence Office's Tradewinds Solutions Marketplace, so DoD buyers can procure it directly.

Prepared by Beag Labs from the Papyrus source. Screenshots are from a test deployment marked SECRET to show the classification banner; they contain no classified information. This overview accompanies the Papyrus evidence pack and is not a certification, an authorization or a third-party assessment.

01 AT A GLANCE

WHAT PAPYRUS IS

Papyrus is an agent runtime an organization deploys itself: one hardened container image or an Azure VM appliance, configured by a reviewable `papyrus.yaml`. Agents work over the organization's documents and connected systems through tools it approves, and people sign, approve and audit what they do.

YOUR ENVIRONMENT

Runs in your network, including disconnected enclaves. Calls no Beag Labs service; licenses verify locally.

YOUR IDENTITY PROVIDER

Sign-in through your OpenID Connect provider or Entra ID. Multi-factor and smart cards stay under your policy.

YOUR MODELS

Only the model gateways you list. Government and disconnected profiles never fall back to a commercial endpoint.

YOUR EVIDENCE

Append-only audit trail, exported to your SIEM over OTLP. Signed agent revisions and run records.

DEPLOYMENT POSTURE

Amazon Linux 2023 image with OpenSSL's certified FIPS 140-3 provider forced on; Papyrus refuses to start outside FIPS mode.	SC-13
Scanned against the DISA STIG profile for Amazon Linux 2023 in CI; signed with build provenance and SBOMs.	CM-2, RA-5, SR-4
Configuration in `papyrus.yaml`: validated at startup, secrets only by reference, recorded with its digest at every start.	CM-6
No first-run setup page. Identity, owners, license, notice and classification all come from the file.	AC-2, CM-6
Three profiles set network posture: commercial, government and disconnected.	AC-4, SC-7

02 CONFIGURATION AS CODE

ONE FILE YOU CAN REVIEW

Everything a deployment needs is in `papyrus.yaml`: identity, owners, notice, classification, sessions, models, audit export, network allow-list and license. There is no setup page and no settings screen that can drift from it.

Found at `PAPYRUS_CONFIG_FILE`, else `/etc/papyrus/papyrus.yaml`. Environment variables override the file; defaults fill the rest.

CM-6

Secrets never appear in the file, only references: `{ file: … }` or `{ env: … }`, so it can be committed and attached to an evidence package.

IA-5

Checked against its schema at startup. An unknown key, a wrong value or an unreadable secret stops startup with every problem listed.

CM-6

`--check-config` prints the effective settings, secrets hidden, and where each came from, then exits.

CM-2

Each start records the file, its digest and every effective setting, and flags a change since the last start.

CM-3, AU-2

PAPYRUS.YAML

```yaml
version: 1

server:
  mode: persistent
  profile: disconnected   # only listed hosts
  publicOrigin: https://papyrus.enclave.mil
  organizationName: Example Command
  tls:
    cert: /etc/papyrus/tls/cert.pem
    key: /etc/papyrus/tls/key.pem

identity:
  oidc:
    issuer: https://login.enclave.mil/realms/papyrus
    clientId: papyrus
    clientSecret: { file: /run/secrets/oidc-secret }
  owners: [isso@enclave.mil]   # first System Owners
  groupRoles:
    papyrus-admins: [Papyrus.System.Owner]
    papyrus-auditors: [Papyrus.Audit.View]
    papyrus-users: [Papyrus.Agents.Execute]

security:
  notice: dow             # DoD notice and consent
  classification: secret  # banner on every screen
  sessions:
    idleMinutes: 15
    maxHours: 12
    concurrent: 3

audit:
  otlp:
    endpoint: https://siem.enclave.mil:4318/v1/logs
    ca: /etc/papyrus/siem-ca.pem
    clientCert: /etc/papyrus/siem-client.pem
    clientKey: /etc/papyrus/siem-client.key

egress:
  allowedHosts:
    - login.enclave.mil
    - llm.enclave.mil
    - git.enclave.mil
    - siem.enclave.mil

models:
  default: enclave
  gateways:
    - id: enclave
      baseUrl: https://llm.enclave.mil/v1
      model: llama-3.3-70b-instruct
      apiKey: { file: /run/secrets/llm-key }

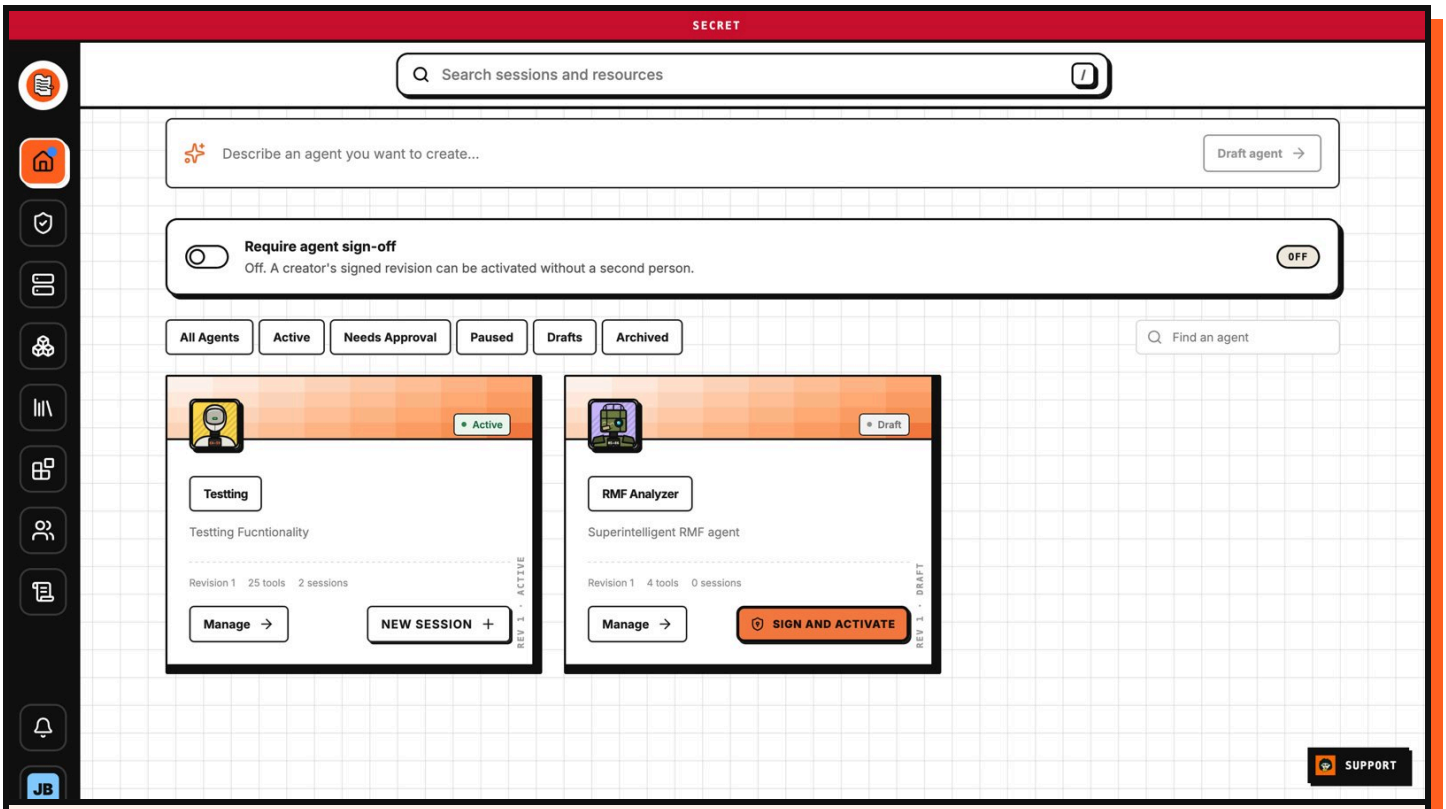
repositories:
  tokens:
    git.enclave.mil: { file: /run/secrets/git-token }

license:
  file: /etc/papyrus/license.json
```

A disconnected deployment marked SECRET: OIDC sign-in, the DoD notice, an enclave model gateway, audit to the SIEM over mutual TLS, and only listed hosts reachable. The JSON Schema for every key is published with Papyrus as `papyrus.config.schema.json`.

03 AGENT ROSTER

NAMED AGENTS, NOT CHATBOTS

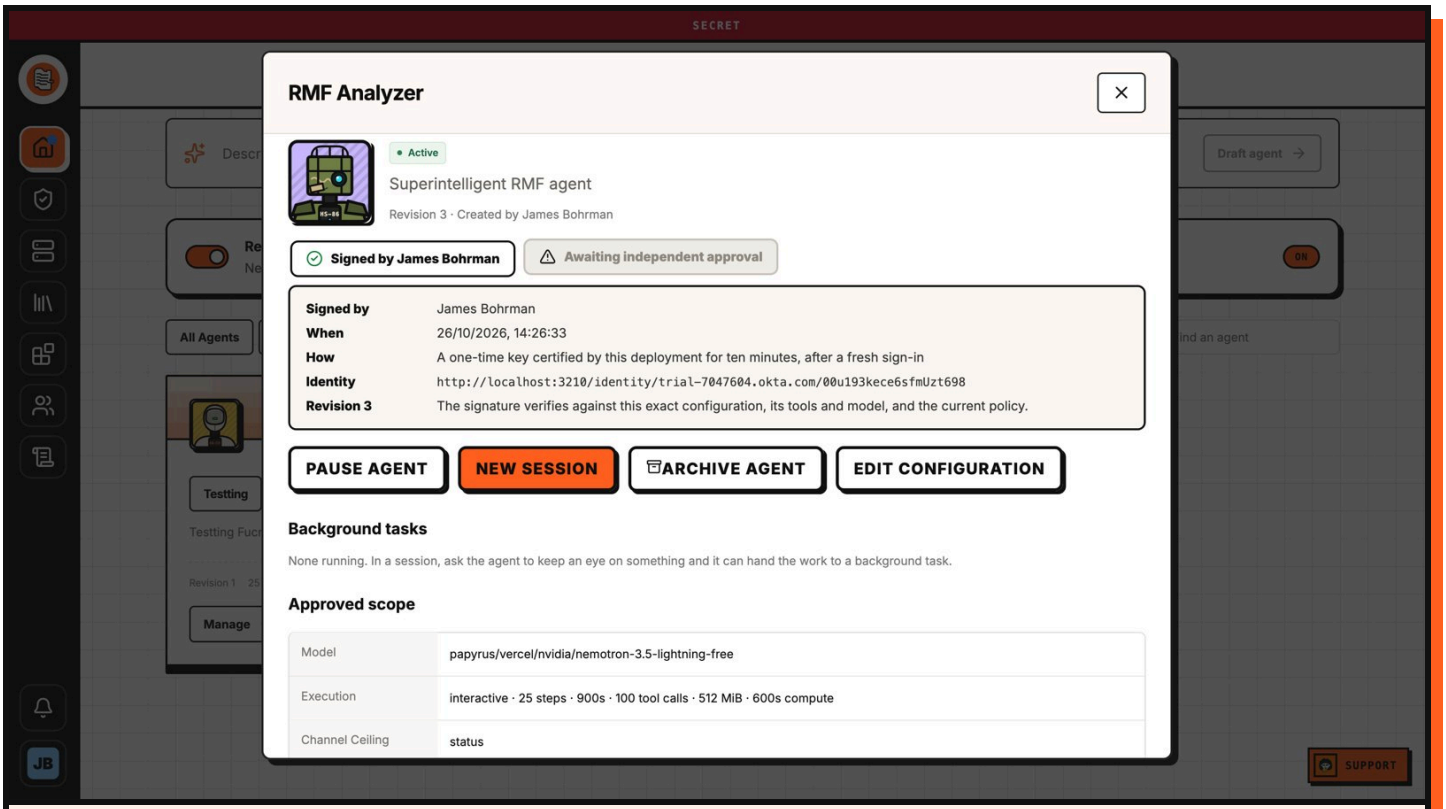


The roster. Each card is a named agent with its state and revision; a draft becomes usable only when it is signed and activated. With **Require agent sign-off** on, a second person must approve every revision.

Every agent is a versioned configuration: instructions, model, limits and channels.	AI RMF GOVERN 1.6
Only an active, signed revision runs. Agents can be paused, archived (deactivated, history kept) or superseded.	AI RMF GOVERN 1.7, MANAGE 2.4
Each agent runs within signed limits: steps, tool calls, time, compute, storage and runs.	AI RMF MANAGE 2.2

04 SIGNED REVISIONS

EVERY CHANGE IS SIGNED



An agent's detail. The creator's signature uses a one-time key certified by the deployment after a fresh sign-in, and verifies against this exact configuration, its tools and model, and the current policy.

Creator and independent approver are recorded by identity on every revision; one person cannot approve their own. AC-5, AI RMF GOVERN 1.4

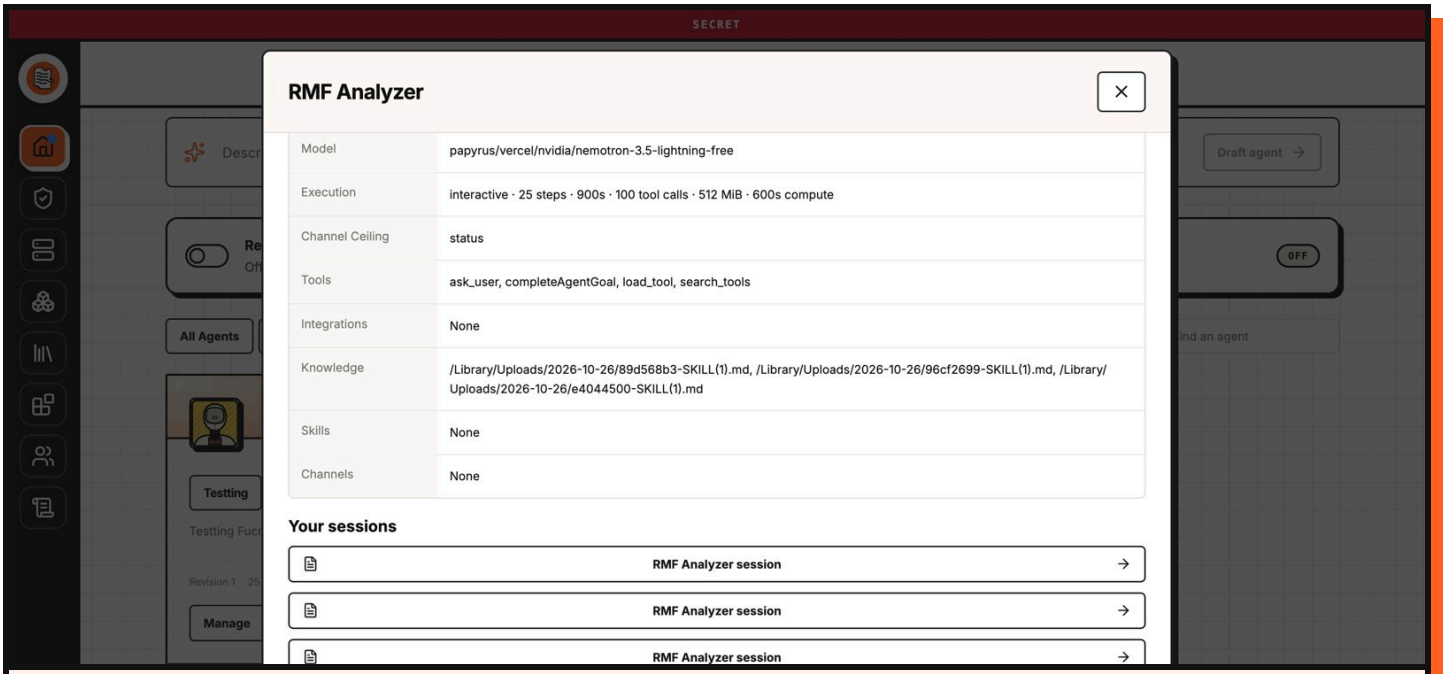
Signatures are Sigstore bundles verifiable outside Papyrus against the deployment's trust root. AI RMF MEASURE 2.8

05 INDEPENDENT AUTHORIZATION

TWO-PERSON REVIEW



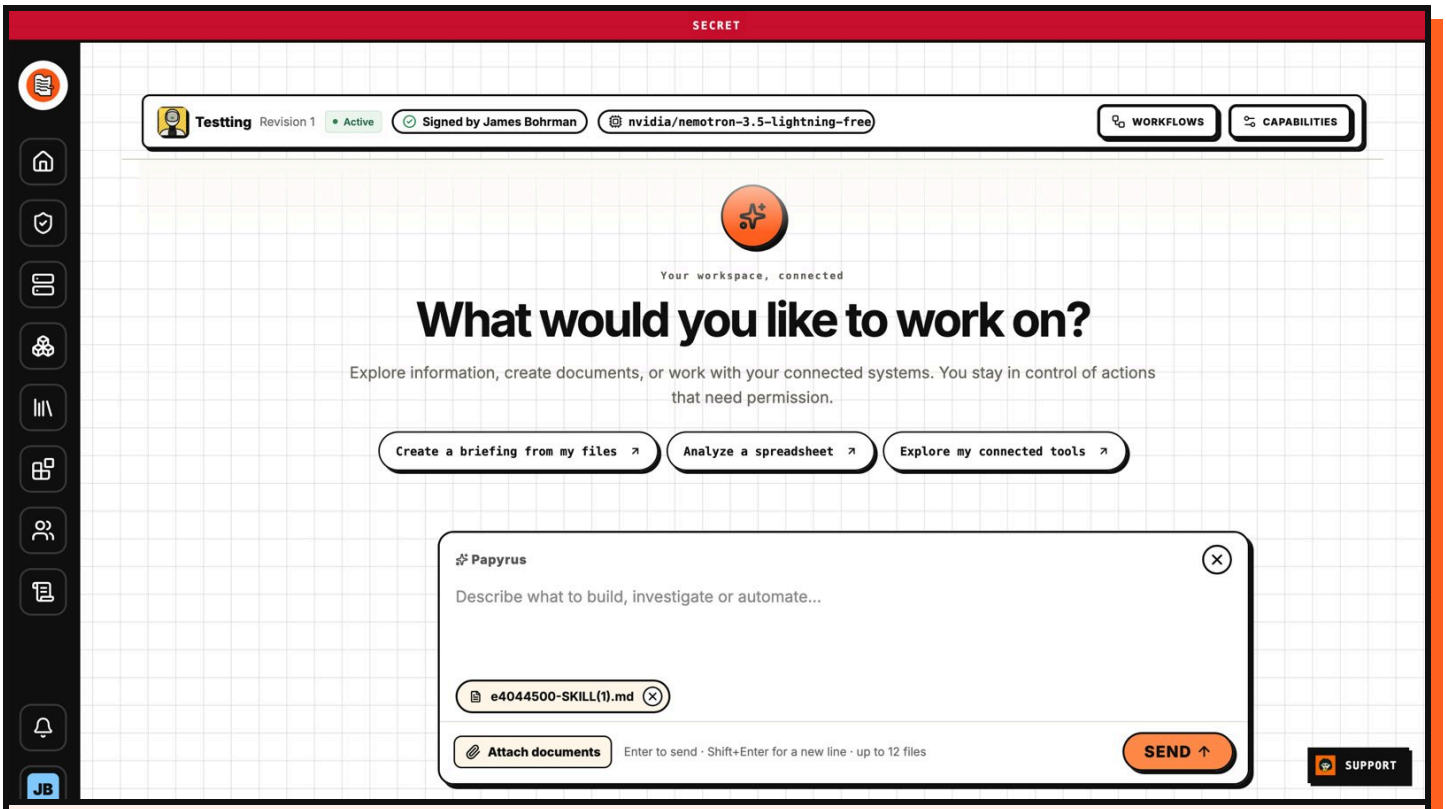
Requests. Reviewers see each revision's configuration against the previous one, verify both signatures, and approve or reject the exact revision.



The approved scope a signature covers: model, execution limits, channel ceiling, tools, knowledge and skills.

06 SESSIONS

PEOPLE STAY IN CONTROL

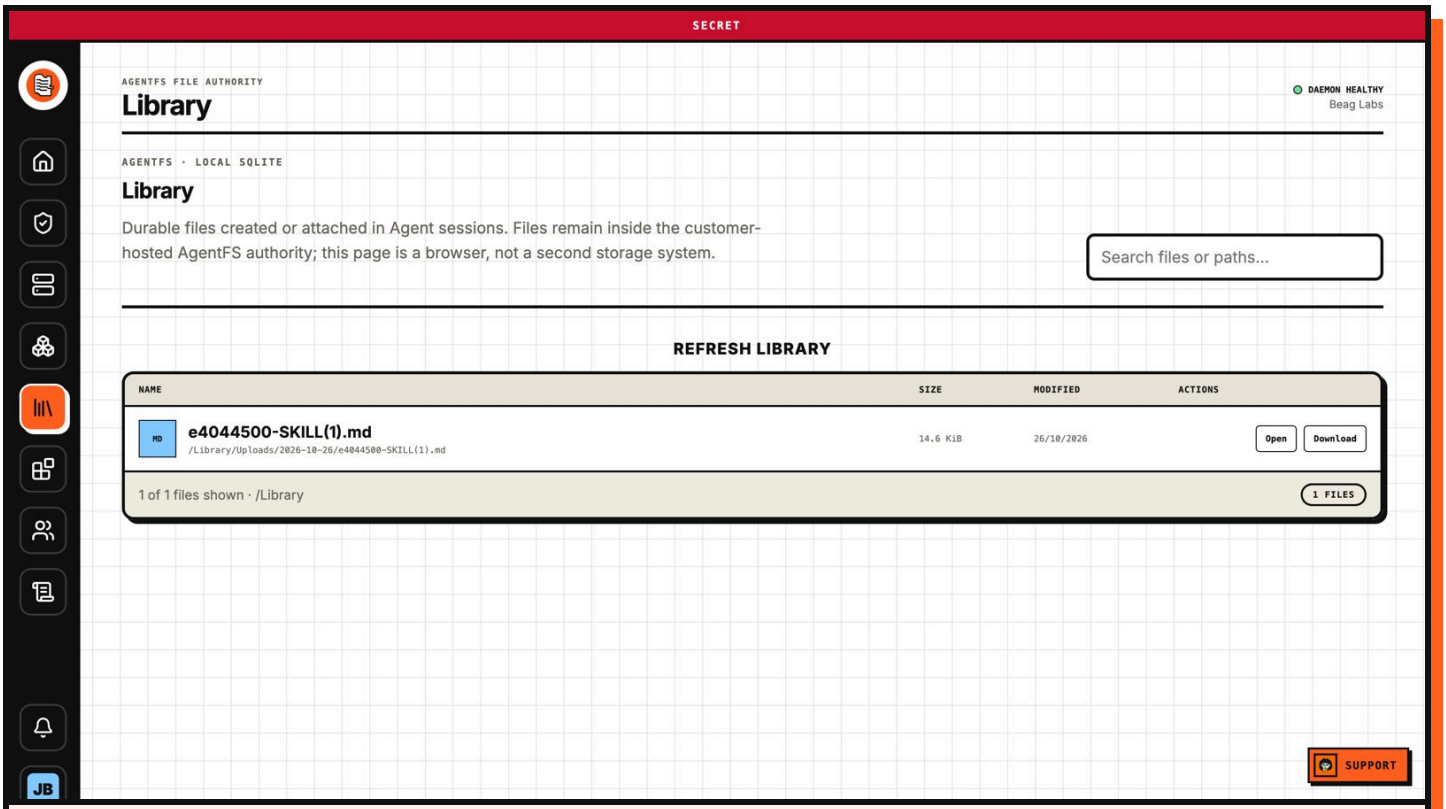


An agent session in a deployment marked SECRET. The header shows the agent, its signed revision and its model; the banner carries the system-high classification on every screen.

Consequential actions are proposed by the agent and approved by a person holding Action.Approve; workflow approval gates wait for the named person or group.	AC-5, AI RMF GOVERN 3.2
Agents ask questions and wait, and notify people through the Inbox when work finishes.	AI RMF MAP 3.5
Agent code runs in a kernel sandbox (Landlock and seccomp) with no network; credentials never reach the model.	SC-39, AC-4
Every action is attributed to the person the agent ran for.	AU-3, AI RMF MEASURE 2.8

07 LIBRARY

DOCUMENTS STAY PUT



The Library browses the durable files agents create or are given. Files remain in the deployment's own store; this page is a browser, not a second copy.

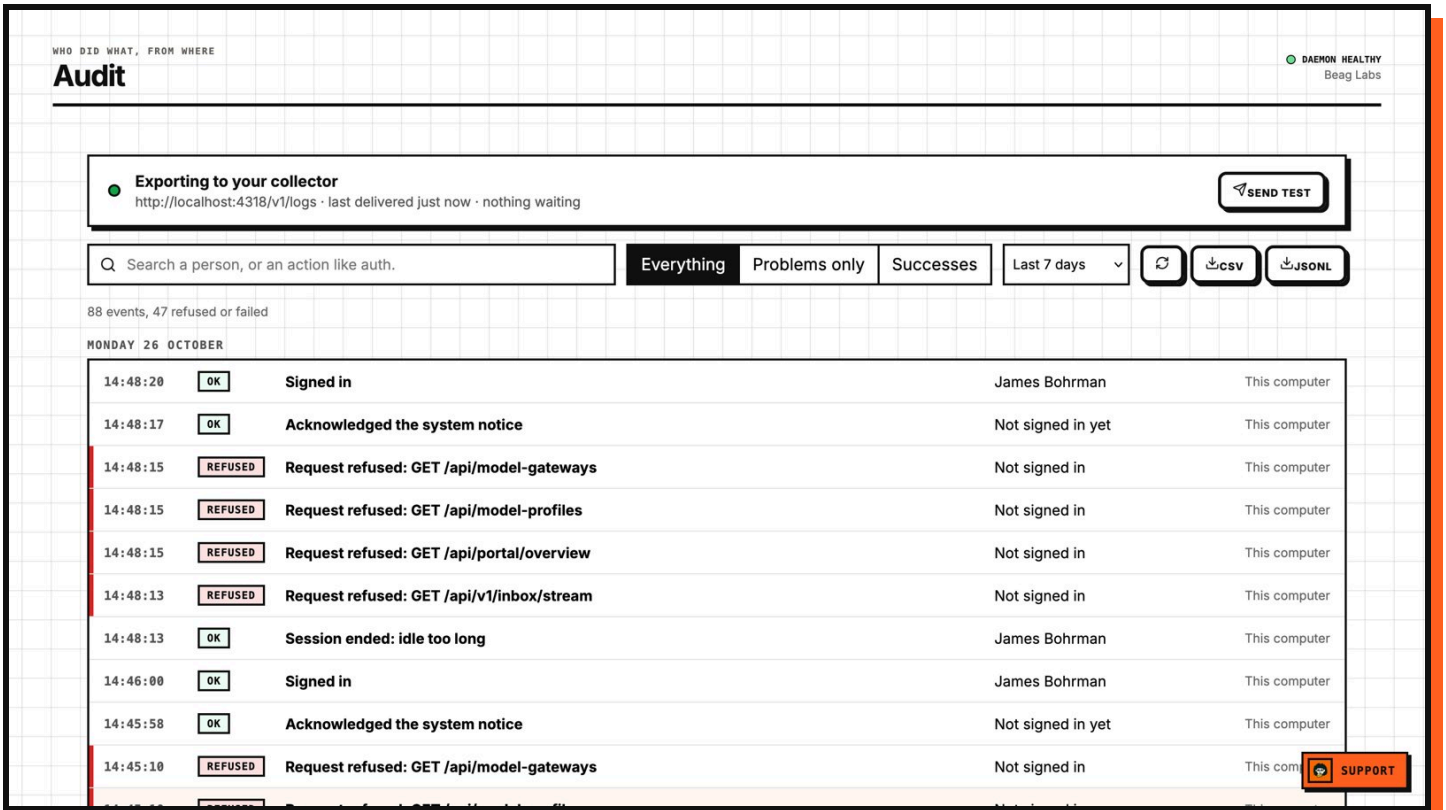
Agents cite Library passages with source path, page and SHA-256. AI RMF 600-1 CONFABULATION

Repositories and packages are downloaded by the server, never the sandbox, through the egress allow-list; nothing in them runs. AC-4, SC-7

Databases overwrite deleted content (secure_delete); credentials are encrypted with AES-256-GCM. SC-4, SC-28

08 AUDIT

WHO DID WHAT, FROM WHERE



The Audit page for System Owners and Audit Viewers: export health, search and filters, each record in full, and CSV or JSONL export.

Sign-ins (and failures), sign-outs, idle session ends, notice acknowledgements, Terms acceptance and every refused request.	AU-2, AC-7
Each record: time, action, outcome, actor and on-behalf-of, target, client address, user agent, request and session IDs.	AU-3
Append-only in the database, and delivered to your OpenTelemetry collector over OTLP (TLS or mutual TLS), resuming after outages.	AU-6, AU-9

09 IDENTITY AND ACCESS

SIGN-IN YOUR WAY

OpenID Connect (Okta, Keycloak, Ping and others) or Microsoft Entra ID, with PKCE, single-use state and nonce.	IA-2
The standard DoD notice and consent banner, or your own text, before sign-in; each acknowledgement audited.	AC-8
Server-side sessions: 15 minutes idle, 12 hours maximum, sign-out revokes, at most 3 per person; all configurable.	AC-10, AC-11, AC-12
Roles from identity-provider groups; first System Owners named in papyrus.yaml; SCIM 2.0 deprovisioning takes effect on the next request.	AC-2
A System Owner accepts the Terms of Service and Privacy Policy in the app before anyone can use it.	AC-3
API keys for automation start only the workflows they name, are stored as keyed hashes and expire.	IA-5

NETWORK BOUNDARY

`egress.allowedHosts` is the only way out for workflow HTTP steps, link previews, MCP servers and repository imports; on the disconnected profile nothing is reached until listed.	AC-4, SC-7
No telemetry to Beag Labs. Error reporting is off unless you set your own Sentry address.	SA-9

10 NIST SP 800-53 REV. 5

CONTROL FAMILIES

50 controls are mapped with source evidence in `papyrus-security-controls.pdf` and `papyrus-controls-matrix.xlsx`, and in OSCAL form. Responsibility is shared: Papyrus enforces what it can in code, and the deploying organization owns the rest.

FAMILY	WHAT PAPYRUS PROVIDES	CONTROLS
Access Control	Roles from the identity provider and papyrus.yaml; server-side sessions with a 15-minute idle limit, 12-hour cap and 3 per person; the DoD notice before sign-in; a system-high classification banner; an egress allow-list for everything agents reach.	IMPLEMENTED AC-7, AC-8, AC-10, AC-11, AC-12 PARTIAL AC-2, AC-3, AC-4, AC-5, AC-6, AC-16
Audit and Accountability	One append-only audit trail of sign-ins, sign-outs, refusals and acceptances, with client address and request IDs; exported to the organization's SIEM over OTLP; reviewed and exported on the Audit page.	IMPLEMENTED AU-3, AU-6, AU-8, AU-12 PARTIAL AU-2, AU-4, AU-9
Configuration Management	papyrus.yaml validated at startup and recorded at every start; one signed, STIG-scanned image; governed changes need a second person; least functionality by design.	IMPLEMENTED CM-3, CM-5, CM-6, CM-7 PARTIAL CM-2, CM-8, CM-14
Contingency Planning	The deploying organization backs up the data directory and its keys; Papyrus documents which files belong together.	CUSTOMER CP-9
Identification and Authentication	OpenID Connect or Entra sign-in with PKCE; multi-factor and smart cards enforced by the identity provider; no local passwords; API keys hashed, scoped and expiring.	IMPLEMENTED IA-2, IA-4, IA-5, IA-8
Incident Response	Owned by the deploying organization; Papyrus supplies the audit trail, traces and agent evidence as inputs.	CUSTOMER IR-4
Risk Assessment	DISA STIG scan of every image in CI and Trivy scans of each released platform in this pack.	PARTIAL RA-5
System and Services Acquisition	Papyrus calls no Beag Labs service; licenses verify locally; security tests run in the repository.	IMPLEMENTED SA-9 PARTIAL SA-11
System and Communications Protection	FIPS 140-3 cryptography enforced at startup; TLS; kernel-sandboxed agent code with no network; encrypted credentials; secure deletion in databases.	IMPLEMENTED SC-8, SC-13, SC-18, SC-23, SC-39 PARTIAL SC-4, SC-5, SC-7, SC-12, SC-28
System and Information Integrity	Signed, digest-pinned updates; input validation at every route; monitoring through traces and the audit trail.	IMPLEMENTED SI-4, SI-7, SI-10 PARTIAL SI-2, SI-11
Supply Chain Risk Management	Signed images with SLSA build provenance and SBOMs for every platform.	PARTIAL SR-4

11 NIST AI RMF 1.0

AI RISK MANAGEMENT

How Papyrus, as the agent runtime an organization deploys, supports the organization's AI risk management. Most AI RMF outcomes are organizational; Papyrus supplies the mechanisms and records that make them practicable and evidences them. Responsibility follows the same shared model as the 800-53 matrix.

FUNCTION	SUBCATEGORIES PAPYRUS SUPPORTS
Govern	**GOVERN 1.4** Risk management process established through transparent policies and controls **GOVERN 1.6** Inventory of AI systems **GOVERN 1.7** Decommissioning AI systems safely **GOVERN 2.1** Roles, responsibilities and lines of communication documented **GOVERN 3.2** Policies define human-AI configurations and oversight **GOVERN 4.3** Practices for testing, incident identification and information sharing PARTIAL **GOVERN 6.1** Policies address risks from third-party AI (models, data, software)
Map	**MAP 1.1** Intended purposes, context and settings documented **MAP 3.5** Processes for human oversight defined **MAP 4.1** Approaches for mapping legal risks of AI components and third-party data CUSTOMER
Measure	**MEASURE 2.4** Functionality and behavior monitored in production **MEASURE 2.7** Security and resilience evaluated and documented PARTIAL **MEASURE 2.8** Transparency and accountability risks examined **MEASURE 2.10** Privacy risk examined **MEASURE 2.11** Fairness and bias evaluated CUSTOMER
Manage	**MANAGE 2.2** Mechanisms to sustain the value of deployed AI **MANAGE 2.4** Mechanisms to supersede, disengage or deactivate AI systems **MANAGE 3.1** Third-party AI risks monitored and controls applied **MANAGE 4.1** Post-deployment monitoring plans implemented

GENERATIVE AI PROFILE

RISK	HOW PAPYRUS ADDRESSES IT
Information security (prompt injection, data exfiltration)	Tool results from MCP servers and documents are labeled as untrusted external content; agent code has no network; outbound requests pass the egress allow-list; consequential actions need human approval.
Confabulation	Agents cite Library passages with source path, page and SHA-256; consequential outputs go through approval; goal completion is declared with a recorded summary of evidence.
Data privacy	Prompts, documents and outputs stay inside the deploying organization's environment; Beag Labs receives no deployment data.
Value chain and component integration	Models are chosen by the organization in papyrus.yaml; dependencies are inventoried in SBOMs; the release image is signed with build provenance.
Human-AI configuration	Signed agent revisions, optional independent sign-off, approval gates and per-agent limits keep a person accountable for what each agent may do.

12 PLAIN DEALING

WHAT IS STILL OPEN

Every partial control has an entry in the known gaps plan and POA&M in the evidence pack. The highest-risk items:

- No third-party assessment or penetration test
- Controls not verified in an authorized hosting environment
- Vulnerability scanning and remediation SLAs not formalized
- RA-5: No dependency or static-analysis scanning runs in CI, and there are no severity-based remediation timeframes.
- SC-28: Agent sessions, Library documents, audit records and traces are stored in unencrypted SQLite and AgentFS files; their confidentiality at rest depends on volume encryption the deploying organization provides.

IN THE EVIDENCE PACK

Security controls	`papyrus-security-controls.pdf`, `papyrus-controls-matrix.xlsx`, `oscal/papyrus-component-definition.json`
AI RMF	`papyrus-ai-rmf.pdf`, `papyrus-ai-rmf.xlsx`
Known gaps	`papyrus-known-gaps.pdf`, `papyrus-poam.xlsx`, `oscal/papyrus-poam.json`
Architecture and deployment	`papyrus-architecture.pdf`, `papyrus-deployment-requirements.pdf`
Supply chain	`papyrus-supply-chain-evidence.pdf`, SBOMs, signature and provenance verification, vulnerability scans

Questions: **legal@beaglabs.com** · Beag Labs, Inc., 102 O Street, Lenoir City, TN 37771